Five-Pillar Federal AI Governance Framework — v2 Addendum

Addendum to v1 Framework Based on Validation Test Findings

Version: 2.0 Addendum **Date:** May 10, 2026 **Status:** Active — supplements v1 framework documents **Origin:** Gaps identified during full-lifecycle validation test (Project SENTINEL scenario + Mythos/Glasswing/Mercor retrospective) **Validation Test Pass Rate:** 96% across 52 discrete tests; this addendum addresses the remaining 4% (two cross-pillar tensions) and strengthens the 17% that passed with caveats

---

Addendum 1 — Seventh Accountability Role: Marketplace / Orchestration Platform

The Gap

The v1 framework defines six roles in the 360° accountability matrix: developer, deployer, contractor, vendor, regulator, and end-user. The validation test identified a seventh entity class that does not cleanly map to any of the six: cloud AI marketplace and orchestration platforms.

AWS Bedrock, Google Vertex AI, Microsoft Azure AI, and similar platforms sit between the model developer and the deployer in the value chain. They are not the developer (they did not train the model). They are not the cloud infrastructure provider in the traditional sense (they add a model-serving layer with its own access controls, logging, billing, and content filtering). They are not the deployer (they do not make mission decisions about how the model is used). They are a distinct intermediary that controls access, routing, and in some cases content moderation between developer and deployer.

Why Existing Roles Do Not Cover This

Developer: The marketplace does not train or fine-tune models. It hosts and serves them. Anthropic builds Claude; Bedrock serves Claude. Assigning developer obligations to Bedrock misallocates accountability for model behavior.

Vendor: The v1 framework uses "vendor" to cover foundation model providers and infrastructure providers. The marketplace combines aspects of both while being neither — it controls the serving layer, applies guardrails, manages rate limits, and produces usage logs that neither the developer nor the infrastructure provider generates. Lumping it into "vendor" loses this specificity.

Contractor: Marketplaces are not engaged under FAR/DFARS contracts in the traditional prime/sub structure. They are consumed as commercial cloud services, often under existing FedRAMP authorizations (Bedrock operates under AWS GovCloud's FedRAMP High authorization). But their AI-specific controls (content filtering, model routing, prompt logging) are not covered by the underlying IaaS FedRAMP authorization.

The v2 Addition

The accountability matrix is extended to seven roles:

Role	Definition	Examples	Key Obligations
Developer	Entity that trains, fine-tunes, or materially modifies a foundation model	Anthropic, OpenAI, Google DeepMind, Meta AI	Model card, system card, safety evaluations, weight security, training data provenance
Marketplace / Orchestration Platform	**Entity that hosts, serves, routes, or mediates access to models without training or deploying them for a specific mission**	**AWS Bedrock, Google Vertex AI, Azure AI, Hugging Face Inference Endpoints**	**Serving-layer access control, API usage logging, content-filter transparency, model versioning and deprecation notice, availability SLA for model endpoints, guardrail documentation**
Deployer	Entity that acquires and operates an AI system for a specific mission purpose	Federal agency (mission owner), system owner	ATO decision, human oversight, continuous monitoring, privacy impact, mission-appropriate use
Contractor	Entity engaged under contract to build, integrate, or maintain an AI system	DIB prime, systems integrator, subcontractor	SSP, POA&M, CMMC attestation, flow-down, incident reporting
Vendor	Entity that provides infrastructure, components, or services consumed by the AI system	Cloud infrastructure (IaaS/PaaS), hardware, training data providers	FedRAMP authorization, physical security, encryption, availability
Regulator	Entity with oversight or enforcement authority	FedRAMP PMO, DCMA DIBCAC, agency OIG, OMB	Audit, enforcement, policy issuance
End-user	Human who operates or is affected by the AI system	Federal employees (operators), citizens (affected persons)	Human-in-the-loop review, override authority, right to appeal

Marketplace-Specific Obligations

The marketplace/orchestration platform role carries six distinct obligations not assigned to any other role:

1. Serving-layer access control. The marketplace controls which identities can invoke which models through its API. This is distinct from the cloud infrastructure's IAM layer — Bedrock has its own model-access permissions on top of AWS IAM. The marketplace must document how these permissions interact and ensure that credential scoping at the marketplace layer is at least as restrictive as the infrastructure layer beneath it.

2. API usage logging. The marketplace generates usage logs (prompt, completion, token counts, latency, model version invoked) that neither the developer nor the infrastructure provider produces. These logs are essential for Pillar 2 (assumed breach) behavioral analytics. The marketplace must make these logs available to the deployer in a format ingestible by the deployer's SIEM, with retention periods meeting the deployer's continuous monitoring requirements.

3. Content-filter transparency. Many marketplaces apply their own content filters, guardrails, or safety classifiers on top of the model developer's built-in safety measures. The marketplace must document what filters are applied, how they interact with the developer's safety measures, and what the deployer's options are for configuration. A deployer cannot make an informed risk assessment if the marketplace applies undocumented safety filters that may suppress legitimate operational outputs.

4. Model versioning and deprecation notice. When a marketplace retires a model version, updates a default model, or changes the underlying model behind a stable endpoint, the deployer must be notified with sufficient lead time to test the replacement against mission requirements. Surprise model changes can invalidate the deployer's evaluation results and break the provenance chain documented in the AIBOM.

5. Availability SLA for model endpoints. The marketplace's availability SLA for model endpoints is distinct from the cloud infrastructure's availability SLA for compute. The deployer's contingency plan (ISCP) must account for marketplace-layer outages separately from infrastructure-layer outages.

6. Guardrail documentation. If the marketplace modifies model behavior through system prompts, RLHF adjustments, or output filtering beyond what the developer ships, these modifications must be documented so the deployer understands what behavior they are actually deploying versus what the developer's model card describes.

Impact on the Concentration Risk Register

The concentration risk register (Pillar 3) must evaluate marketplace concentration as a distinct dimension from both model and infrastructure concentration. A deployer using Claude via Bedrock has three independent concentration risks: Claude (model), AWS (infra), and Bedrock (marketplace). A multi-model strategy (Claude + GPT-4.5) does not mitigate marketplace concentration if both models are accessed through the same marketplace.

Addendum 2 — Ninth Concentration Dimension: Authorization / Compliance

The Gap

The v1 framework's concentration risk register evaluates eight dimensions: vendor, model family, foundation model, GPU compute, cloud region, dataset, tooling/MLOps, and identity/auth. The validation test identified a ninth dimension: authorization and compliance dependence.

Why This Matters

A federal AI system's authorization to operate depends on a chain of compliance artifacts: FedRAMP authorization (or equivalent), CMMC assessment (for DoD), ATO from the agency authorizing official, and potentially state-level certifications. Each link in this chain is a potential single point of failure:

FedRAMP concentration. If the system operates under a single FedRAMP authorization and that authorization is revoked, suspended, or lapses during re-authorization, the entire system loses its authorization to operate. The 2025 EO churn and early-2026 OMB rescissions of M-22-18 and M-23-16 demonstrated that the authorization landscape can shift rapidly.

C3PAO concentration. If the system's CMMC assessment depends on a single C3PAO and that C3PAO's accreditation is revoked — as the Delve AI / Mercor situation suggests can happen — the assessment must be repeated with a different C3PAO. This creates a re-assessment timeline (typically 3-6 months) during which the system's compliance status is in question.

ATO concentration. If the system operates under a single agency ATO and the authorizing official changes (common during administration transitions), the new AO may require re-evaluation before reaffirming the ATO. A system designed for multi-agency use but authorized under a single agency ATO has authorization concentration risk.

The v2 Addition

The concentration risk register is extended to nine dimensions:

Dimension	What to Evaluate	Single-Provider Risk	Mitigation Strategy
1. Vendor	Primary service provider	Total system dependency	Multi-vendor strategy
2. Model family	Foundation model lineage	Capability lock-in	Multi-model abstraction
3. Foundation model	Specific model version	Behavior change on update	Version pinning + regression testing
4. GPU compute	Hardware supply chain	Capacity constraints	Reserved instances + spot market diversity
5. Cloud region	Geographic deployment	Regional outage	Multi-region active-active or warm standby
6. Dataset	Training and evaluation data	Bias / quality lock-in	Independent validation sets
7. Tooling/MLOps	Pipeline infrastructure	Rebuild cost	Portable pipeline (Kubeflow, MLflow)
8. Identity/auth	Authentication infrastructure	Total access failure	Redundant auth paths
9. Authorization / compliance	**FedRAMP, CMMC, ATO, C3PAO**	**Loss of authority to operate**	**Reciprocity agreements, multi-agency ATOs, diversified 3PAO relationships, continuous ATO (cATO) posture**

Scoring for the Authorization Dimension

The same likelihood × blast radius × recovery cost framework used for the other eight dimensions applies:

Likelihood: How likely is the authorization to be disrupted? Consider: authorization expiration date, re-authorization timeline, regulatory environment stability (high churn = higher likelihood), C3PAO accreditation status, and administration transition risk.

Blast radius: What percentage of the system becomes unauthorized if this authorization lapses? If the entire system operates under a single FedRAMP authorization, the blast radius is 100%.

Recovery cost: How long does re-authorization take? FedRAMP re-authorization: 6-12 months. CMMC re-assessment with a new C3PAO: 3-6 months. Agency ATO re-evaluation under a new AO: 1-3 months.

Addendum 3 — Failover Test Plan Template

The Gap

The v1 framework requires tested failover for multi-model and multi-region deployments (Pillar 3) but does not provide a test plan template in docs/artifacts. Practitioners know they need failover; they need a structured way to test it.

Failover Test Plan Template

This template should be added to `docs/artifacts/checklists/` as `failover-test-plan-template.md`.

1. Failover Scenario Inventory

For each concentration risk rated HIGH in the concentration risk register, define a failover scenario:

Scenario ID	Trigger Event	Component Affected	Failover Target	Detection Method	Expected RTO
F-001	Primary model API returns 503 for >5 minutes	Foundation model endpoint	Secondary model (different provider)	Health check + circuit breaker	< 30 seconds
F-002	Primary cloud region outage	All compute in us-gov-west-1	Warm standby in us-gov-east-1	AWS health dashboard + custom monitor	< 15 minutes
F-003	C3PAO accreditation revoked	CMMC assessment validity	Pre-qualified backup C3PAO engagement	Regulatory monitoring alert	< 30 days to initiate
F-004	Model version deprecated by marketplace	Current model version	Pinned previous version or alternative model	Marketplace deprecation notification	< 7 days
F-005	Identity provider outage (SPIFFE root CA)	All workload identity	Backup root CA with offline key ceremony	Certificate monitoring	< 1 hour

2. Pre-Test Checklist

Before executing any failover test:

- Confirm that the failover target is provisioned and receiving configuration updates (warm standby) or can be provisioned within the expected RTO (cold standby)
- Verify that monitoring and alerting for the failover trigger is active and has been validated independently
- Notify all stakeholders listed in the ISCP
- Confirm that test execution will not impact production data integrity (use synthetic test data where possible)
- Document the current baseline performance metrics for comparison after failover

3. Test Execution Protocol

For each scenario:

Step 1 — Inject failure. Simulate the trigger event. For model API failover, block the primary endpoint at the network layer. For region failover, simulate a region outage by disabling the primary deployment. Do not rely on waiting for a real failure.

Step 2 — Measure detection time. Record the elapsed time from failure injection to the first alert firing. Compare against the expected detection time.

Step 3 — Measure failover time. Record the elapsed time from first alert to the failover target serving production traffic. Compare against the expected RTO.

Step 4 — Validate functional equivalence. Run the standard evaluation suite against the failover target. Compare outputs to the primary system's baseline. For model failover, this means running the same evaluation prompts and comparing output quality, latency, and safety filter behavior. Document any functional degradation.

Step 5 — Validate evidence chain continuity. Confirm that the hash-chained evidence registry (Pillar 5) continues to record entries during and after failover. Confirm that SIEM telemetry (Pillar 2) captures the failover event. Confirm that the AIBOM is updated to reflect the failover model if applicable.

Step 6 — Failback. Restore the primary system and confirm that traffic routes back correctly. Measure failback time.

4. Post-Test Documentation

Field	Content
Scenario ID	F-XXX
Test date	YYYY-MM-DD
Tester(s)	Names and roles
Trigger injection method	How the failure was simulated
Detection time (actual vs expected)	Seconds/minutes
Failover time (actual vs expected)	Seconds/minutes
Functional equivalence result	Pass / Partial / Fail with details
Evidence chain continuity	Confirmed / Gaps identified
Failback time	Seconds/minutes
Issues discovered	Description + severity
Remediation actions	What will be fixed before next test
Next scheduled test	Date

5. Test Cadence

Failover tests must be executed at a minimum cadence based on concentration risk level:

- **CRITICAL risk (score 16-25):** Quarterly
- **HIGH risk (score 10-15):** Semi-annually
- **MODERATE risk (score 5-9):** Annually

Results are incorporated into the POA&M if issues are discovered, with remediation timelines mirroring FedRAMP standards (High 30 days, Moderate 90 days, Low 180 days).

Addendum 4 — Cross-Pillar Implementation Patterns

The Gap

The v1 framework documents cross-pillar interactions at the conceptual level ("Pillar X reinforces/tensions with Pillar Y") but does not provide implementation patterns for resolving the two tensions identified in the validation test:

1. Identity federation across diverse model providers (Pillar 3 × Pillar 4)
2. Governance-infrastructure resilience (Pillar 1 × Pillar 3)

Pattern 1: Identity Federation Across Diverse Model Providers

The tension: Pillar 3 requires multi-vendor model diversity to mitigate concentration risk. Pillar 4 requires unified zero-trust identity governance. When a deployer uses models from multiple providers (each with its own authentication mechanism), the identity infrastructure must provide a consistent policy enforcement layer without becoming a new single point of failure.

Implementation pattern:

Key design decisions:

a) SPIFFE as the unified identity layer. All workloads receive SPIFFE SVIDs from a shared trust root. The SVID is the canonical identity. Provider-specific credentials (Bedrock IAM roles, Azure service principals, Vertex AI service accounts) are derived from the SVID through provider-specific adapter services. The adapters are stateless translators — they map SVID claims to provider credentials at request time and do not store standing credentials.

b) Policy Decision Point redundancy. The PDP must be deployed as an active-active pair (minimum) across independent failure domains. If the PDP uses a SPIFFE server (e.g., SPIRE), the SPIRE servers must run in at least two availability zones with a shared datastore that itself is replicated. This addresses the Pillar 3 requirement that zero-trust infrastructure not be a concentration risk.

c) Provider adapter isolation. Each provider adapter runs in its own microsegmented workload (Firecracker microVM or gVisor sandbox). A compromise of one adapter (e.g., through a provider API vulnerability) does not expose the credentials for other providers. This is Pillar 2 (assumed breach) applied to the identity infrastructure itself.

d) Per-session, per-provider credential scoping. The adapter issues a provider-specific credential for each session. The credential's scope is the intersection of the SVID's claims and the provider's minimum required permissions. Credential lifetime matches the SVID lifetime (30-minute rotation). No standing credentials exist at the provider layer.

e) Unified audit trail. All identity decisions (SVID issuance, provider credential derivation, access grants, access denials) are logged in the hash-chained evidence registry (Pillar 5). A single query to the registry answers "who accessed which model, through which provider, with what credential, at what time" regardless of which provider was invoked.

Pattern 2: Governance-Infrastructure Resilience

The tension: Pillar 1 requires governance baked into the deployment substrate. Pillar 3 requires that no single component failure causes total system failure. If the governance infrastructure itself is a single point of failure, a system outage simultaneously disables both the operational system and the governance controls that protect it.

Implementation pattern:

a) Separate the governance plane from the operational plane. The governance infrastructure (policy engine, evidence registry, monitoring pipeline, compliance dashboard) must run on independent infrastructure from the operational AI system. If the AI system runs on EKS in GovCloud us-gov-west-1, the governance plane should run on independent compute — ideally in a different availability zone or region, or on a different platform entirely (e.g., a dedicated governance cluster or a SaaS governance platform with its own FedRAMP authorization).

b) Governance operates in degraded mode, not off mode. If the governance plane becomes unavailable, the operational system must enter a degraded mode where:

- New requests are still served (to maintain mission availability) but at a reduced trust level (e.g., human-in-the-loop required for all recommendations, not just high-risk ones)
- All operational events are buffered locally with cryptographic timestamps for later ingestion into the evidence registry when the governance plane recovers
- An alert fires to the SOC indicating governance-plane degradation
- A pre-defined maximum degraded-mode duration is enforced (e.g., 4 hours), after which the operational system enters maintenance mode if the governance plane has not recovered

c) Evidence registry uses append-only, replicated storage. The hash-chained evidence registry (Pillar 5's substrate primitive) must use append-only storage replicated across at least two independent storage backends. Sigstore's Rekor transparency log provides one model: entries are append-only, cryptographically chained, and independently verifiable. The deployer should maintain a local replica in addition to the Rekor public log.

d) Policy-as-code is version-controlled and cached. The policy engine's rules (expressed as OPA/Rego policies, Cedar policies, or equivalent) are stored in a version-controlled repository with signed commits. The policy engine caches the active policy set locally so that a repository outage does not prevent policy enforcement. Policy updates are pulled on a schedule (e.g., every 5 minutes) with fallback to the cached version.

e) Monitoring pipeline has independent alerting. The monitoring pipeline (SIEM ingestion, anomaly detection, alert routing) must have at least one alerting path that does not depend on the primary monitoring infrastructure. A simple out-of-band alerting mechanism (e.g., a heartbeat monitor on independent infrastructure that alerts if the primary monitoring pipeline stops reporting) ensures that a monitoring failure is itself detected.

Addendum 5 — Behavioral Analytics Baseline Methodology for AI Agents

The Gap

Pillar 4 requires behavioral baselines for AI agents to detect anomalous credential usage and unauthorized access patterns. No federal standard or published methodology exists for establishing such a baseline. CAISI Agent Standards (RFI closed March 9, 2026) and the NCCoE concept paper on AI agent identity (February 2026) are pre-publication. The framework must provide a provisional methodology until authoritative guidance is available.

Provisional Methodology

This methodology establishes a behavioral baseline for AI agents operating within a federal deployment. It is designed to be replaced by CAISI or NIST guidance when published, but to be operationally useful in the interim.

Step 1 — Agent Identity Registration

Before an AI agent is deployed, register it in the workload identity system (SPIFFE/SPIRE) with the following metadata:

Attribute	Description	Example
Agent ID	Unique identifier (SPIFFE ID)	spiffe://va.gov/sentinel/claims-parser
Agent type	Functional classification	Document parser, recommendation generator, quality checker
Authorized data sources	Which data stores the agent may access	VistA/CPRS (read), VBMS (read), OMPF (read)
Authorized actions	What operations the agent may perform	Parse document, extract structured data, generate recommendation
Authorized communication peers	Which other services/agents it may call	claims-parser → recommendation-engine, recommendation-engine → human-review-queue
Expected invocation pattern	Normal usage hours, frequency, volume	Weekdays 0600-2200 ET, 50-200 invocations/hour, batch processing weeknights
Maximum context window per session	Token budget per invocation	128K tokens input, 4K tokens output
Maximum credential scope per session	Narrowest credential the agent needs	Read access to single veteran's claims file per invocation

Step 2 — Baseline Collection Period

After deployment, observe the agent's actual behavior for a baseline collection period of 30 calendar days (minimum 20 business days of operational activity). During this period:

Collect the following telemetry for every agent invocation:

- Timestamp
- Source identity (SPIFFE SVID)
- Destination identity (data source or peer agent)
- Action performed
- Data volume accessed (bytes/tokens)
- Response latency
- Session duration
- Geographic origin (IP/network segment)

- Error rate

Compute the following baseline statistics:

- Mean and standard deviation for: invocations per hour, data volume per invocation, session duration, response latency
- Distribution of invocation times (by hour of day, day of week)
- Distribution of data sources accessed (frequency per source)
- Distribution of peer agents communicated with
- Error rate baseline

Step 3 — Anomaly Detection Thresholds

Set detection thresholds at three tiers based on baseline statistics:

Tier 1 — Advisory (log, no action):

- Any metric exceeds 2σ from baseline mean
- Invocation during non-standard hours (within 2 hours of normal boundary)
- Access to an authorized data source not accessed in the past 7 days

Tier 2 — Alert (log + notify SOC):

- Any metric exceeds 3σ from baseline mean
- Invocation during non-standard hours (outside 2-hour boundary)
- Access pattern inconsistent with registered agent type (e.g., document parser attempting to write to a data store)
- Communication with a peer agent not in the authorized communication peers list
- Session duration exceeds 3× baseline mean

Tier 3 — Block (deny action + notify SOC + trigger IR):

- Agent attempts to access a data source not in its authorized list
- Agent attempts an action not in its authorized actions list
- Credential scope exceeds registered maximum
- Data volume per session exceeds 5× baseline mean (potential exfiltration)
- Agent identity cannot be verified (SVID validation failure)
- Geographic origin outside authorized network segments

Step 4 — Baseline Refresh

The behavioral baseline is not static. Refresh it according to the following schedule:

- **Full baseline recalculation:** Every 90 days using the most recent 30 days of telemetry
- **Incremental update:** Weekly, incorporating the previous week's telemetry with exponential decay (recent observations weighted more heavily)
- **Forced reset:** After any significant change to agent configuration, authorized data sources, or deployment architecture — begin a new 30-day baseline collection period

Step 5 — Integration with Pillar 2 and Pillar 5

Pillar 2 integration: Behavioral anomaly detections at Tier 2 and Tier 3 generate entries in the incident response log using the following format:

Field	Value
Detection source	Agent behavioral analytics
Agent ID	SPIFFE ID
Anomaly tier	1 / 2 / 3
Anomaly description	Metric, observed value, baseline value, threshold
MITRE reference	ATT&CK technique ID and/or ATLAS technique ID
Automated response	Log only / SOC notification / Action blocked
IR escalation required	Yes / No

Pillar 5 integration: All baseline calculations, threshold settings, anomaly detections, and baseline refresh events are recorded in the hash-chained evidence registry with the identity of the person who approved the threshold settings. This ensures that behavioral analytics decisions are auditable and traceable to a named accountable party.

Limitations and Forward Compatibility

This provisional methodology has known limitations:

- It does not address multi-agent orchestration chains where one agent's anomaly triggers cascading behavioral changes in downstream agents
- It uses statistical thresholds (σ-based) rather than ML-based anomaly detection, which may produce higher false-positive rates for agents with highly variable workloads

- It does not address the "cold start" problem for newly deployed agents that have no behavioral history

These limitations should be addressed when CAISI Agent Standards or equivalent NIST guidance is published. The methodology is designed to be replaceable: the telemetry collection (Step 2) and the Pillar 2/5 integration (Step 5) remain valid regardless of what anomaly detection methodology supersedes Steps 3-4.

Summary of v2 Changes

Addendum	What Changed	Pillars Affected	Artifacts Added or Modified
1	Seventh accountability role: Marketplace / Orchestration Platform	Pillar 5 (primary), Pillar 3 (concentration register)	Accountability allocation matrix extended to 7 roles; marketplace obligation register
2	Ninth concentration dimension: Authorization / Compliance	Pillar 3 (primary), Pillar 5 (accountability for authorization chain)	Concentration risk register extended to 9 dimensions
3	Failover test plan template	Pillar 3 (primary), Pillar 2 (detection during failover), Pillar 5 (evidence chain continuity)	New template: failover-test-plan-template.md
4	Cross-pillar implementation patterns for P3×P4 and P1×P3 tensions	Pillar 1, 3, 4 (cross-cutting)	Two implementation architecture patterns with deployment diagrams
5	Behavioral analytics baseline methodology for AI agents	Pillar 4 (primary), Pillar 2 (integration), Pillar 5 (integration)	Agent identity registration schema, baseline collection protocol, three-tier anomaly detection thresholds

Backward Compatibility

All v2 additions are additive. No v1 content is modified or superseded. Organizations that have begun implementing v1 can adopt v2 additions incrementally — Addendum 3 (failover test plan) and

Addendum 5 (behavioral analytics baseline) are the highest-priority additions for organizations in the implementation phase.

Next Validation Cycle

The v2 additions should be validated through the same methodology used for v1: a synthetic federal deployment scenario tested against every claim the addendum makes. The recommended test focuses on:

- Addendum 1: Does the seven-role matrix correctly allocate accountability for a Bedrock-mediated deployment?
- Addendum 4: Does the identity federation pattern survive a simulated provider adapter compromise?
- Addendum 5: Does the behavioral analytics baseline detect the Mythos-pattern unauthorized access (credential reuse by an unauthorized party with a different usage pattern)?